SECUREFLOW

Cloud Security Alert Triage Workflow

Prepared by: Harshiv Desai

1. Problem Statement

Cloud security teams receive alerts from multiple cloud accounts and services. Investigating each alert often requires switching between tools to verify evidence, understand the affected asset, assess business impact, and decide what action to take. This fragmented workflow can delay critical response, create inconsistent prioritisation, and make remediation difficult to audit.

2. Target User Persona

PRIMARY USER

Cloud Security Engineer / Security Analyst

This user monitors alerts across cloud environments, investigates potential misconfigurations or exposures, determines severity and business impact, coordinates remediation, and maintains an auditable record.

Key needs are to identify urgent risks quickly, validate alerts with clear evidence, understand affected resources, and remediate safely without disrupting services.

3. Proposed Solution and Core User Flow

SecureFlow provides a guided workflow from detection to verified resolution:

1	**Alert Queue** — view alerts in one place and filter by severity, status, cloud account, and age;
2	**Investigation** — inspect the alert description, affected resource, evidence, timeline, potential impact, and recommended action;
3	**Remediation** — review the proposed change, understand its impact, explicitly confirm or cancel, and view the outcome in an audit trail.

EXAMPLE

SecureFlow flags a storage bucket that appears publicly accessible. The engineer reviews the evidence and affected resource, checks the recommendation to block public access, confirms the change, and receives an auditable result showing who acted, what changed, and when.

4. Feature Prioritisation

Priority	Scope	Rationale
MVP / P0	• central alert queue • severity and status filters • alert detail with evidence and asset context • recommended next step • permission-checked confirmation before a production change • remediation result and audit log	These capabilities support the core job: make a sound triage decision and resolve a verified risk safely.
Next / P1	• saved filters • alert assignment • comments • notification rules	These improve team coordination but are not essential to validate the core journey.
Later	• bulk remediation • advanced cross-cloud analytics • configurable automation	Introduced after reliability, permissions, and user trust are established.

5. Success Metrics

Primary metric

Median time from alert creation to first meaningful triage decision (for example, confirmed true positive, false positive, or accepted risk).

Supporting metrics

- percentage of critical alerts triaged within the agreed SLA
- median time from confirmed alert to verified remediation
- percentage of alerts with a recorded disposition

Guardrails

- unintended or failed remediation rate
- reopened-alert rate
- false-positive closure rate
- service-impact incidents following remediation

6. Development Action Items

- Define a consistent alert data model, severity mapping, status lifecycle, and deduplication rules.
- Integrate cloud asset metadata, policy findings, and supporting evidence.
- Implement role-based access control and approval requirements for sensitive actions.
- Build remediation preview, execution status, failure handling, and a safe rollback path where supported.
- Record immutable audit events and instrument the agreed product metrics.
- Validate the workflow with security engineers before expanding automation.

7. Assumptions and Scope

This concept assumes alerts can be normalised across supported cloud providers and remediation APIs are available for selected actions. The MVP focuses on one high-value alert type (publicly accessible storage) to validate the workflow. SecureFlow recommends and facilitates action; it does not silently modify production resources.

> **FIGMA LINK**
>
> https://www.figma.com/design/oTiVWLTlBeUIWOfffwvJCU/SecureFlow?node-id=0-1&t=glQwql29pkZI4Lcd-1